GRC Workshop Case Study: UTS Hiking Society Risk Assessment

Risk assessment, UTS Hiking Society, fictional client

Antoine Husser

12 September 2026

Workshop exercise, CSECCon V

Contents

Executive summary 3

Scope and methodology 4

Interview evidence 5

Risk register 7

Remediation plan 10

Assumptions and open questions 11

What I took from it 11

Executive summary

Former committee members can still sign in to the UTS Hiking Society's role email accounts. The passwords sit in the committee chat and nobody has ever changed them. The club also could not tell us what member data it holds, where the copies are or who can read them. We logged six risks, two rated High and four Medium. The first thing to do is change the four role-account passwords, switch on multi-factor authentication and delete the passwords from the chat. Everything we recommend is free, and four students can get it done before re-registration.

Scope and methodology

In a team of four, I assessed how a fictional student club handles its members' personal data. My part was asking the interview questions, drafting the risks and writing the recommendations.

We looked at how the club collects, stores, shares and retains member data.

Workshop	"Think Like a Cyber Risk Consultant"
Event	CSECCon V, UTS Cyber Security Society (CSEC)
Delivered with	Skylight Cyber Security
Date	12 September 2026
Format	Around 65 students in 12 teams, each acting as cybersecurity consultants
My team	Team 1, four members
Client (fictional)	UTS Hiking Society

Scenario and sources

The Hiking Society had not been breached. What started the review was an email from ActivateUTS, sent to clubs after a real incident at another club. The committee forwarded it and did nothing with it. Re-registration was coming, and Sam, the president, would have to explain how the club handles member data.

We started with incomplete information. What we learned came from interviewing AI personas who played the committee: Maya, the secretary, and Dan Marchetti, the treasurer. Priya, who runs events, was mid-exams and we could not reach her.

What surprised me was how far apart the answers were depending on who we asked. We ended up putting each question to both personas. One would answer in general terms while the other knew how things really worked, which makes sense given they hold different roles. The member sheet is the clearest case: Maya first named four fields, Dan listed twelve.

Some questions went nowhere. Asked whether the previous treasurer is removed from the account, Dan said "No idea, sorry. That's not my area." Maya answered "I don't know" when we asked about multi-factor authentication. Both points are still open.

We wrote each finding as cause, event, impact and affected party, so that someone non-technical can follow it. An early line from our working notes: "There is a risk of unauthorised access to the club and member data caused by an ex-committee member due to the passwords never being changed."

Limitations

Our evidence is interviews only. We did not inspect any account setting or sharing configuration, and Priya was not interviewed. Some statements come from the team's written notes and do not appear in the screenshots; the risk register marks these as "team notes". We cite no framework, because we could not confirm which standard or privacy principle applies to a student club.

Interview evidence

These are screenshots from our interview with Dan Marchetti, the treasurer persona. Each one backs a finding.

Shared credentials, never rotated (finding 1)

Each role has its own account, handed down with the same password, which sits in the committee chat.

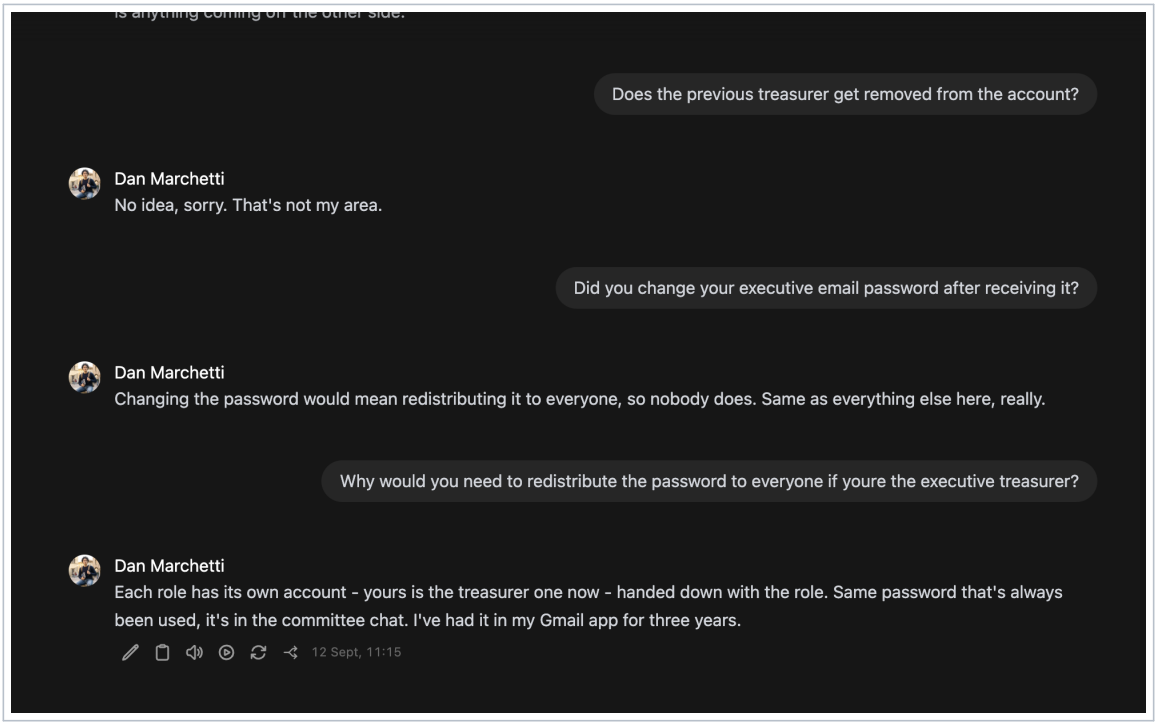


Figure 1. Shared credentials, never rotated (finding 1)

Excessive collection (finding 4)

The sheet holds twelve fields, including date of birth, medical conditions, allergies and blood type.

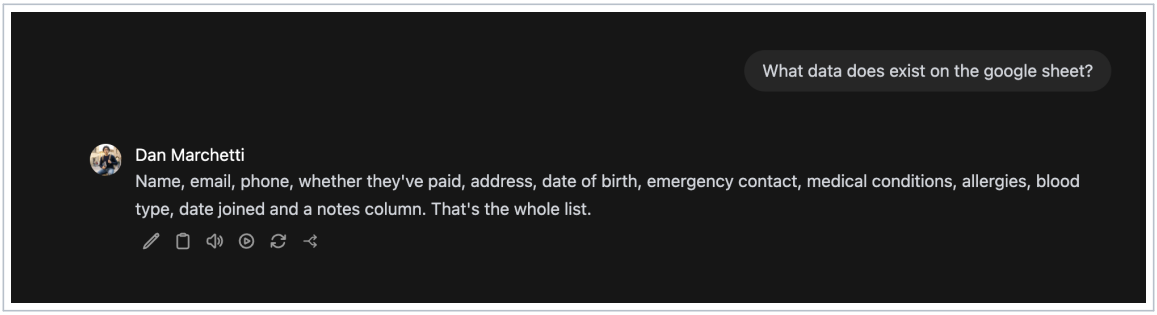


Figure 2. Excessive collection (finding 4)

No retention rule

Nothing has ever been deleted across about four years of members.

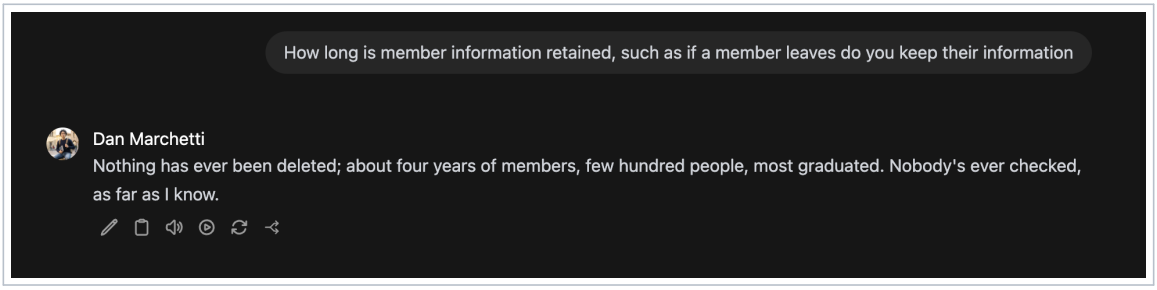


Figure 3. No retention rule

Past misuse

A committee member used the sheet to contact a member about a non-club matter.

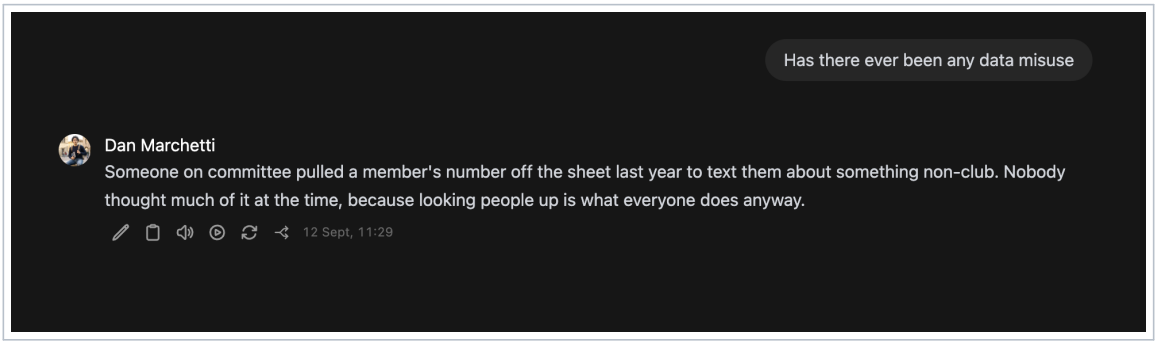


Figure 4. Past misuse

Risk register

R1 and R5 are rated High. In both, people who should no longer have access still do.

Rating scale

Likelihood: High = already occurring or enabled by routine practice; Medium = plausible under current practice, not yet observed; Low = needs unusual circumstances. Impact: High = exposure of health or identity data, or of years of correspondence, for several hundred people; Medium = loss of control over records, or risk to affiliation; Low = inconvenience only. Risk level: High when both are High; Medium when one is High or both are Medium; Low otherwise.

Evidence labels

"Confirmed" = stated by a persona in our interview records. "Team notes" = recorded in the team's written findings only. "Contradiction" = personas disagreed. "Deduction" = the team's inference.

ID	Risk statement	Asset	Affected party	Missing or failing control	Likelihood	Impact	Level	Evidence
R1	There is a risk of former committee members signing in to role email accounts, caused by shared passwords that are stored in the committee chat and never changed, resulting in unauthorised reading and export of years of member correspondence.	Role email accounts	Members past and present; Sam as the officer signing re-registration	Password rotation, removal of access at handover, individual credentials	High	High	High	Confirmed (Dan): each role account is handed down with the same password, which is in the committee chat; nobody changes it because it would have to be redistributed. Team notes: Dan confirms at least a couple of former members still have access; the chat is on Messenger.
R2	There is a risk of the club losing control of its sign-up and event records, caused by the form and response sheets being owned by the secretary's personal Google account, resulting in records the club cannot transfer, audit or delete.	Sign-up form and event response sheets	The club; members and non-member attendees; Maya personally	Ownership of club records by a role account	High	Medium	Medium	Team notes: Maya built the form and event sheets under her own login, ownership was never moved, and she does not know how sharing is configured.
R3	There is a risk of member data leaking from an untracked copy, caused by routine full-sheet exports, uncleared event sheets, retained paper forms and manual BCC mailouts, resulting in exposure the club cannot contain or recall.	Exports, event sheets, paper forms, sent mail	Members; the club	Register of copies, limits on export, deletion after use	Medium	High	Medium	Team notes: Dan exports the full sheet before every promotional email and paid event; no event sheet has been cleared; Maya pastes about 140 addresses into BCC by hand.

ID	Risk statement	Asset	Affected party	Missing or failing control	Likelihood	Impact	Level	Evidence
R4	There is a risk of health and identity data being exposed in any incident, caused by the club collecting fields it does not use, resulting in harm well beyond the loss of a contact list.	Member Google Sheet and sign-up form	Members and non-member attendees	Data minimisation, a defined purpose for each field, a data inventory	Medium	High	Medium	Confirmed (Dan): the sheet holds name, email, phone, payment status, address, date of birth, emergency contact, medical conditions, allergies, blood type, date joined and notes. Contradiction: Maya first named four fields. Team notes: the form was copied from the futsal club.
R5	There is a risk of people with no current role in the club opening the member sheet, caused by access being granted each O-Week and never removed, resulting in an unknown and growing number of people able to read every member's details.	Member Google Sheet	Members; the club at re-registration	Access review, removal of access after events and at handover	High	High	High	Confirmed (Maya): O-Week helpers get the sheet link and nobody removes their access afterwards. Confirmed (Dan): the sheet is opened from a link pinned in the committee chat. Contradiction (team notes): Maya believes four people have access; Dan says former committee members still do.
R6	There is a risk of the club being unable to account for its data handling at re-registration, caused by the absence of any privacy notice or retention rule and an unactioned ActivateUTS warning, resulting in risk to affiliation and loss of member trust.	Club affiliation; member trust	Sam; the club; members	Collection notice, retention rule, action on external warnings	High	Medium	Medium	Confirmed (Dan): nothing has ever been deleted across about four years of members. Team notes: the form carries no privacy statement; the ActivateUTS email was forwarded to committee and not read.

Rating rationale

ID	Likelihood	Impact
R1	High: working credentials are already held by former members.	High: the inboxes hold years of member correspondence and the club cannot list who has access.
R2	High: the records already sit outside the club's control and ownership was never moved.	Medium: the harm is loss of control; no exposure was reported.
R3	Medium: copies are created routinely, but no leak was reported.	High: each export contains the full member row.
R4	Medium: exposure depends on another risk occurring first.	High: the fields include health information and date of birth for a few hundred people.
R5	High: past helpers still hold the link, and a committee member has already used the sheet for a non-club purpose.	High: the sheet contains every field for every member.
R6	High: the club has no notice or retention rule to show when asked.	Medium: affiliation is at risk; no direct data exposure.

Remediation plan

Seven actions cover the six risks. They cost nothing and are sized for four student volunteers. A1 goes first: it is the only action that cuts off access people have right now. We never found out the re-registration date, so the later deadlines are set relative to it.

ID	Action	Risks treated	Owner	Effort	Deadline	Priority
A1	Change the four role-account passwords, turn on multi-factor authentication, and delete the passwords from the committee chat. Each role holder sets their own password; Sam keeps recovery access. Add "change the password" to the handover checklist.	R1	Sam, with each role holder	One evening	Immediately	1
A2	Restrict the member sheet to the four current executives as named people and turn link sharing off.	R5	Not established during interviews	Part of two sittings	Before re-registration	2
A3	Transfer ownership of the sign-up form and all event response sheets to the secretary role account.	R2	Maya	Part of two sittings	Before re-registration	2
A4	List every copy of member data: member sheet, form responses, event sheets, exports, paper folder and sent mail.	R3, R6	Not established during interviews (one person)	Part of two sittings	Before re-registration	2
A5	Reduce the copies: shred transcribed paper forms, delete past event sheets and exports, stop full exports, and give Dan a view showing only name and paid status.	R3	Dan and Maya (deduction: they hold the copies)	Part of two sittings	Before re-registration	2
A6	Remove blood type, address, date of birth and notes from the form and the sheet. Collect emergency details only for a trip that needs them and delete them afterwards.	R4	Not established during interviews	One afternoon	Before re-registration	3
A7	Add a three-line notice to the form: what is collected, why, and how long it is kept. Delete member records two years after last renewal and event lists 30 days after the event. Delete the graduated members now. Write the rule into the handover document.	R6, R4	Not established during interviews	One afternoon	Before re-registration	3

Deleting the passwords from the chat does not remove them from former members' message history, which is why changing them is the control that matters.

Assumptions and open questions

Assumptions made by the team

We assumed Maya is the secretary. That comes from her duties and the secretary role account; nobody told us so. The team notes say the committee chat is on Messenger, while the screenshots only say "committee chat". Our view that the club does not use blood type, address, date of birth or the notes column is a judgement drawn from the interviews.

Open questions

- [ ] Is multi-factor authentication enabled on any role account? The secretary persona answered "I don't know".
- [ ] Do former treasurers still have access to the club bank account? Dan answered "No idea". The point appeared in early notes and is excluded from the register as unconfirmed.
- [ ] Who holds members' payment details? The question was asked and no answer was recorded.
- [ ] Who exactly can open the member sheet today? Maya and Dan disagree, and no access list was produced.
- [ ] How is sharing configured on the forms and sheets in Maya's personal account?
- [ ] What does the ActivateUTS email require, and when is re-registration? Nobody interviewed had read the email.
- [ ] Which other clubs can enter the room where the paper forms are kept?
- [ ] What would Priya (events) and Sam (president) add? Priya was unavailable; an interview with Sam is not recorded in our notes.
- [ ] Who on the committee will own actions A2, A4, A6 and A7?

What I took from it

The interviews were the hard part. A question asked once gave me one person's version, and the second persona often described something quite different. Asking twice and comparing became the method, and the disagreement between Maya and Dan about the sheet turned into a finding of its own.

The instructors helped me with how to word a question and which kinds of questions to ask. If I did the exercise again, I would use that from the first interview.

The rest was practice in writing a risk so that a non-technical client can follow it, ranking access that exists today above what might happen later, and keeping the fixes within reach of a volunteer committee.